Unidad 2: Vulnerabilidades y Controles ISO 27001

Detección y mitigación con herramientas en Kali Linux

Objetivo

Relacionar el análisis de vulnerabilidades con la gestión de riesgos en ciberseguridad, utilizando herramientas especializadas (Nmap, OpenVAS, Nessus) en Kali Linux para la detección y evaluación de vulnerabilidades, considerando controles de ISO 27001 como referencia de mitigación.

Relación con lo visto en Unidad 1

Identificamos amenazas (malware, sniffing, DoS, ingeniería social) y aplicamos mecanismos de protección básicos (firewalls, VPN, AAA).

Avanzamos a **detectar vulnerabilidades reales** en sistemas y redes, usando herramientas especializadas, y proponemos medidas correctivas con base en ISO 27001.

Análisis de Vulnerabilidades y Gestión de Riesgos

Vulnerabilidad = debilidad técnica.

Riesgo = impacto si se explota la debilidad.

Fases de gestión de riesgos

Identificación → Análisis → Evaluación → Tratamiento → Monitoreo

Herramientas Especializadas

Nmap: escaneo de puertos y servicios.

OpenVAS (Greenbone): escaneo profundo con **Common Vulnerabilities and Exposures** (*Vulnerabilidades y Exposiciones Comunes*).

Nessus: auditorías comerciales avanzadas.

Relación ISO 27001: A.12.6.1 (gestión de vulnerabilidades técnicas).

Identificación de Riesgos

Localizar y documentar activos, amenazas y vulnerabilidades.

En una oficina, los activos críticos son los servidores, los PCs con datos contables y el acceso a internet. Un puerto abierto sin control es una vulnerabilidad que podría ser explotada.

```
nmap -sn 192.168.10.0/24
```

Análisis de Riesgos

Examinar cómo las vulnerabilidades pueden ser explotadas y qué impacto tendría.

Un puerto RDP abierto (3389) en Windows 10 es una vulnerabilidad. Riesgo: un atacante podría entrar y controlar el equipo.

```
nmap -sV 192.168.10.15
```

Evaluación de Riesgos

Asignar nivel de riesgo según **probabilidad** e **impacto**.

Si RDP está abierto a toda la red, la probabilidad de ataque es ALTA y el impacto es ALTO → Riesgo crítico.

```
nmap --script vuln -p3389 192.168.10.15
```

Tratamiento/Mitigación de Riesgos

Definir y aplicar medidas para reducir los riesgos a un nivel aceptable.

Un servicio vulnerable debe parchearse, restringirse o deshabilitarse.

```
# En Windows 10: Deshabilitar RDP si no es necesario, o configurarlo para aceptar solo conexiones desde pfSense.
# En pfSense: Crear regla de firewall para bloquear puerto 3389 desde redes externas.

nmap -p3389 192.168.10.15
```

Monitoreo y Mejora Continua

Revisar constantemente el estado de los sistemas, aplicar actualizaciones y repetir análisis de vulnerabilidades.

Un riesgo mitigado hoy puede reaparecer si se actualiza mal un sistema o se cambia la configuración.

```
# Configurar en pfSense el registro de logs de tráfico bloqueado.
# Repetir escaneos periódicos desde Kali para validar que no aparezcan nuevos puertos abiertos.
# Documentar en informe técnico la evolución de riesgos.
```

Cierre

Lo aprendido:

- La gestión de riesgos no es solo detectar (Nmap/OpenVAS), sino **documentar, priorizar y mitigar**.
- Cada fase es aplicable incluso en un laboratorio sencillo como pfSense + Windows + Kali.

Pregunta guía:
“Si mañana aparece un nuevo puerto abierto en Windows 10, cómo aplicarías el ciclo de gestión de riesgos paso a paso?”